2026 深圳国际金融科技大赛 · 必交材料

轻融金

安全自评报告

权限分级实现说明与已知风险清单

评估更新：2026-11-01。范围：Vue Banking 应用、Go Banking Service、Python/LangGraph、Coze 桥接、模型费用网关及隔离部署材料。

自评结论

项目已实现分层认证、账户/任务范围绑定、确定性金融执行网关、数据库角色分离与租户 RLS、模型费用预占和独立执行确认。已有隔离运行证据支持相关控制；本次以源码和历史证据核对为主，不宣称完成第三方审计或生产渗透测试。

维度	自评状态	说明
访问控制/执行门禁	已实现，有隔离证据	生产接入需重新核验部署
真实 AI 完整性	部分通过	最新整月规划通过，文字解读失败
供应商费用结算	未完成	usage/估算不充当正式账单
真实金融执行	未接入	六类金融执行均为模拟
本次材料处理	最小化导出	不带供应商秘密、数据库转储或有效授权

安全自评描述已核实的控制和限制，不出具“无风险”或合规认证结论。

01 资产、威胁与信任边界

资产	主要威胁	对应控制
账户/交易/目标	越权读取、金额伪造	Go 所有权校验、整数金额、数据库权限
任务/检查点	跨用户恢复、旧租约提交	RLS、owner 上下文、租约与请求摘要
授权/幂等	重放、陈旧计划、重复资金执行	prepare/authorize/execute、版本、幂等
模型费用	越预算、绕网关、未知后重复调用	审批指纹、预占、请求数与并发限制
密钥/会话	浏览器暴露、日志与源码泄漏	服务器注入、脱敏、HttpOnly、最小化导出
账单文本/模型输出	提示注入、伪造工具与引用	结构/白名单/账户绑定、引用可见性校验

浏览器与模型输出均为不可信输入。Agent 不拥有金融数据库写权限；Coze 的工作流范围不是银行资金授权。应用的 origin 校验不替代部署网络出口限制。

数据最小化

演示与回归使用合成金融数据；源账单备注不作为系统指令。最新修复只将唯一报告引用交给解读模型，完整来源证据继续保存在 Go 结果和报告中，减少上下文与不必要标识暴露。

internal/orchestrator/explanation.go:122、executor.go:543；banking_agent/source.py、banking.py。

02 权限分级与认证实现

级别	授予方式	允许的操作	拒绝的操作
匿名	无	健康/登录能力	账户与任务数据
本人用户	已认证会话	本人资源和明确确认	其他用户资源
Agent	短期任务委托	白名单 READ/PLAN/PREPARE	资金执行及任意 URL/SQL
后台 Worker	服务密钥 + 受限 capability	有效租约内的原任务	凭历史用户 bearer 扩权
DB 运行角色	显式连接与最小 GRANT	获准表/列 DML + RLS	DDL、BYPASSRLS
迁移/运维	本机显式流程	指定隔离库迁移/材料确认	由公开接口升级为运维

会话

JWT 校验 HS256、issuer、audience、到期及签发时间；身份取自服务器认证上下文。刷新令牌是 HttpOnly / SameSite=Strict cookie；refresh/logout 校验 Origin，跨站请求拒绝。访问令牌仅存页面内存，刷新恢复由服务器决定。

开发与生产区别

本机 HTTP 演示明确允许非 Secure cookie；生产默认要求 Secure 与 HTTPS。开发短信收件箱不证明真实手机号归属，不能作为银行 KYC。提交材料不把本地配置描述为生产安全验收。

identity/identity.go:92；httpapi/userauth.go:41、262、292；config/config.go:66；frontend/ai-banking/src/lib/store.ts、src/api/auth.ts。

03 任务、数据与金融执行控制

数据库

Python 运行角色不得是数据库/表/schema 所有者、超级用户或 BYPASSRLS。租户表 ENABLE/FORCE ROW LEVEL SECURITY；事务内 set_config(app.user_id, …, true)，连接回池清除上下文。迁移角色与运行角色分开；应用启动校验角色与迁移版本。

工具与模型

Supervisor 只能选择现有工具。Go 对账户、时间、目标和方案参数重新校验；业务金额以持久数据和确定性算法为准。专业工作流必须显式启用且具有 ID/发布版本/Canvas 授权绑定，manifest 不能扩大 Approval 范围。

执行授权

规划确认不产生金融执行。prepare 冻结参数与版本，authorize 由本人核对，execute 再校验授权与幂等。当前接入为模拟金融网关，不直接连接真实银行或商户。

故障与重放

Worker 通过事务租约和 journal 持久化恢复。未知调用不盲目重放；旧租约不能提交结果；等待本人确认时停调度。数据库故障与模型超时返回明确状态，不显示虚假成功，不清除既有费用占额。

migrations/001_projection.sql、003_background_scheduler.sql；banking_agent/repository.py:105、128；internal/execution；httpapi/langgraph.go。

04 模型费用、确认与秘密控制

单一费用边界

供应商调用必须经过现有 modelgateway 与 modelspend。Policy 绑定币种、价格与 token 限额；Approval 绑定用户、任务、数据库、工作流、预算、次数与并发。有效期采用带时区时间，结束边界拒绝请求。

独立确认

精确执行计划文件、期望 SHA256 与独立确认摘要必须一致。实际执行要求 READY；候选计划只允许非发送预检。计划内容变更后原确认失效，不从旧周期继承确认。预检不创建 grant、费用预占或金融意向。

秘密与出口

供应商 Key/PAT 不进入浏览器、manifest、普通日志或参赛包。只有已获授权且门禁有效的运行环境可通过受保护 Secret 注入。生产凭据服务 origin 要求 HTTPS；开发内部 HTTP 仅允许显式批准的目标。真实出口还需独立网络控制。

未知与正式结算

unknown、reported、reserved 分别保留，不因停机、换审批或重建 UI 清除。供应商 usage、系统估算、预占与正式结算分开。历史字段名 usage_status=settled 仅表示旧 token 计量完成，不能表述为供应商金额已结算。

cmd/model-gateway/execution_plan.go:82—120；internal/modelspend/approval.go:104、169；internal/outbound/policy.go:20；internal/modelgateway。

05 已知问题与风险清单

下表区分已确认问题、业务边界与未完成的生产检查；严重度表示发布前处理优先级，不把所有缺项都定性为可利用漏洞。

ID / 优先级	事实与影响	处置/当前状态
R01 / 高	尚无真实银行、发卡或商户执行集成；误标会误导用户	界面标模拟；不用于真实资金，未接入
R02 / 高	历史整月解释超上下文、初版建议泛化；失败证据保留	v0.0.9已真实复验通过单项；更广泛质量待评估
R03 / 高	无官方消费明细，unknown/report 不能确认是否收费	保留占额与原始日志，等待正式对账
R04 / 中	用户校对月份完整性不等于银行鉴真；建议可能受漏账影响	标注来源、局限，不承诺可省金额
R05 / 中	本机 HTTP/开发短信不满足公网身份与传输要求	限制回环；生产 TLS/KYC 未验收
R06 / 中	提示注入与供应链风险未完成独立攻击评估	已有确定性工具边界；专项渗透/SCA 未执行
R07 / 中	灾备、HA、生产监控与恢复演练未覆盖全栈	仅有隔离 Worker/DB 故障证据，生产待验收

R02源码：orchestrator/explanation.go、executor.go、coze/billing_explanation_quality.go；历史E3—E5及最新E9。R03：E3 / ledger-integrity-final.json。R04：E2 与源账单声明页面。其余为明确边界或 NOT_INSPECTED。

06 自评方法、证据与提交包检查

本次执行

读取现有代码与验收索引；只读查询指定容器身份与本机公开就绪接口；整理权限分级和已知风险；白名单导出源码、部署模板与测试；扫描导出包中的敏感文件名和高置信度凭据格式；检查文件哈希、尺寸和文档渲染。实际结果及退出码保存在同目录“验收记录”。

历史证据复用

六类只读自然语言、门禁、Worker/数据库恢复和RLS按历史批次引用。E3的FAIL保留；新增E9证明v0.0.9一项账单真实链路与具体建议。当前核心未据共享直连提示词重建，真实Coze使用另行确认发布的v0.0.9。

未执行

本次材料更新不读供应商秘密、不新增模型调用、不改应用、数据库或费用记录。此前E9的两次真实调用已有独立授权并保留日志；不能与材料制作的0次混淆。第三方渗透、全量SCA、真实金融操作及正式账单对账仍未完成。

材料保留与回滚

源码包不含 .git、node_modules、.venv、实际 .env、数据库转储、会话或有效费用审批；保留合成 CSV 样本与上游许可。回滚本轮材料只撤下交付文件，不操作应用和数据。已有关联费用、未知任务与授权历史保持原状。

证据E1—E9路径见技术文档末页，最新非敏感结果见源码evidence/real-billing-v9-20261101.json。安全材料未将任何候选引用或文件摘要升级为真实供应商权限证明。